

Unrestricted Access to Sensitive Business Flows

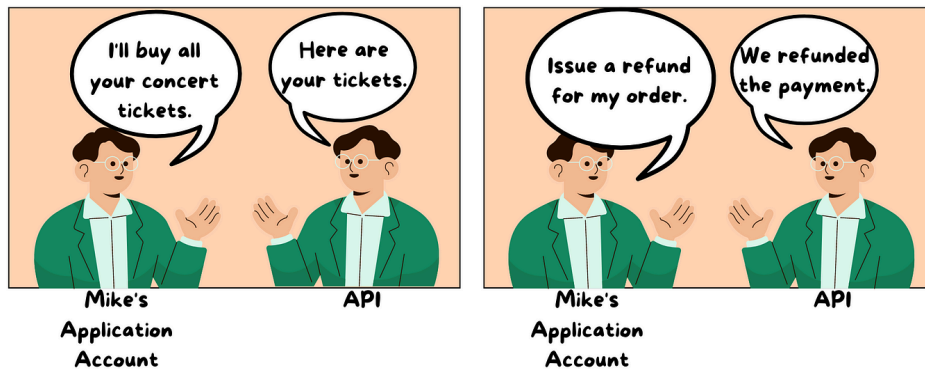
Introduction

What is Unrestricted Access to Sensitive Business Flows?

According to research on API security:

Insufficient access restrictions on an API endpoint can lead to a vulnerability where sensitive business flows are exposed. It is vital to carefully assess these flows since some hold sensitive data that, if accessed without restrictions, could cause significant harm.

What is Unrestricted Access to Sensitive Business Flows?



Vulnerabilities and Root Causes

- **Inadequate Access Control Measures**

- Failing to properly regulate who can access what within a system leads to potential unauthorized access.

- **Weak Authentication Mechanisms**

- Implementing authentication processes that are easily bypassed or compromised allows unauthorized individuals to gain access.

What is the impact of this issue?

- **Resource Consumption**

- Using up server power like CPU, memory, or network space can make the API slower or even unavailable.

- **Brute Force Attacks**

- Unrestricted access can facilitate gaining unauthorized access to individual accounts and organizations.

Case Study

Abusing an Airline's Ticket System

An example of exploiting an Unrestricted Access to Sensitive Business Flows vulnerability would be booking 90% of flight seats online, knowing there is no cancellation fee.

The Vulnerability (Unrestricted Flow)

The ticket system allows users to book and cancel seats without any restriction or penalty. This lack of business logic validation enables an attacker to occupy a majority of flight seats without any financial risk.

The Attack

The attacker cancels all tickets just before the flight, costing the airline nothing. This forces the airline to sell tickets at a major discount to fill the flight, allowing the attacker to buy a cheaper ticket while harming the airline financially.

Result

The airline suffers significant financial loss and operational disruption. This exploitation shows how business-critical flows can be manipulated when they are not properly restricted or monitored.

Mitigations

- **Logging and Monitoring**

- Maintain detailed logs of API access and monitor for any suspicious activity.

- **Authentication and Authorization**

- Implement robust mechanisms to ensure that only authorized users or systems can access sensitive business flows.

- **Business Flow Review**

- Conduct periodic reviews of API endpoints to identify and address any vulnerabilities in business logic.

Conclusion

Unrestricted access to sensitive business flows arises when API endpoints lack proper restrictions, leading to severe financial and operational damage. To protect organizations, it is critical to implement strong access controls, continuous monitoring, and thorough validation of all business-critical operations to prevent exploitation.

References

<https://owasp.org/API-Security/editions/2023/en/0xa6-unrestricted-access-to-sensitive-business-flows/>

<https://my.f5.com/manage/s/article/K000135939>

<https://medium.com/serverlessciso/what-the-owasp-api-security-top-10-2023-means-for-serverless-applications-6477091f231e>